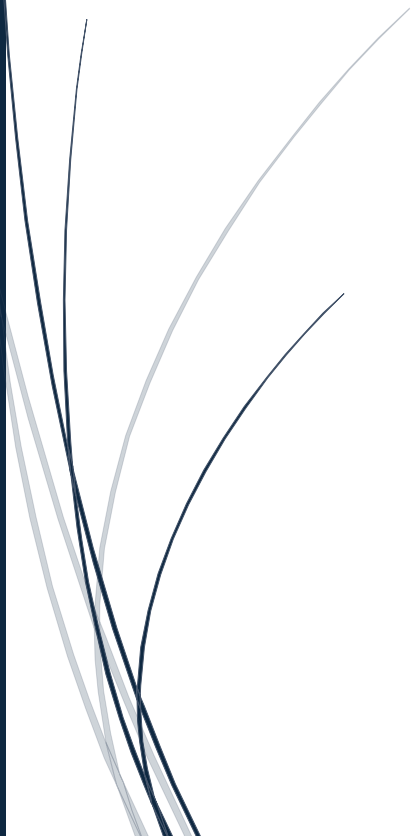




Tema 6 Ciberseguridad

Apuntes



Contenido

Unidad 6 Ciberseguridad	4
1. Seguridad y Privacidad de la Información	4
1.1. Seguridad y privacidad en el entorno digital actual.....	4
1.2. La seguridad de la información.....	5
1.3. La privacidad de la información	6
1.3.1. Marco legal.....	7
1.3.2. Derechos de los individuos	7
1.3.3. Diferencias entre seguridad y privacidad.....	7
1.3.4. Relevancia en la era digital.....	7
2. Tratamiento de la información	8
2.1. Ciclo de vida de la información	8
2.1.1. Recopilación	8
2.1.2. Almacenamiento	9
2.1.3. Uso	9
2.1.4. Eliminación.....	10
2.2. Clasificación de la información	11
2.3. Protección de la información.....	12
3. Almacenamiento de la información.....	13
Importancia del almacenamiento seguro	14
3.1. Copias de seguridad	15
Copia completa	15
Copia incremental.....	15
Copia diferencial.....	16
Estrategia 3-2-1	16
Pruebas periódicas.....	17
3.2. Borrado seguro de la información	17
3.2.1. Métodos de borrado seguro.....	17
Sobrescritura	17
Degradación magnética (degaussing)	17
Destrucción física	17

3.2.2.	Importancia del borrado seguro	18
4.	Principales amenazas a la información	18
4.1.	Panorama actual	18
4.2.	Objetivos de los atacantes	19
4.3.	Phishing.....	19
4.4.	Malware.....	20
	Tipos principales	20
5.	Contraseñas y autenticación.....	22
5.1.	La importancia de las contraseñas	22
5.2.	Buenas prácticas en la gestión de contraseñas	22
5.3.	Autenticación multifactor (MFA)	23
	Factores de autenticación	24
6.	Protección del puesto de trabajo	24
6.1.	Medidas de protección física.....	25
6.2.	Medidas de protección lógica.....	26
	Áreas principales	26
	Conclusiones.....	27

Unidad 6 Ciberseguridad

1. Seguridad y Privacidad de la Información

1.1. Seguridad y privacidad en el entorno digital actual

En la sociedad contemporánea, la información se ha consolidado como uno de los **activos estratégicos más valiosos** tanto para individuos como para organizaciones. La progresiva **digitalización de la economía, la administración pública y la vida cotidiana** ha transformado la manera en que se producen, almacenan, transmiten y consumen datos. Hoy en día, procesos tan sensibles como la gestión financiera, la historia clínica electrónica, las transacciones de comercio electrónico o el control de infraestructuras críticas dependen de sistemas informáticos interconectados.

La llamada “**sociedad de la información**” se caracteriza por una creciente interdependencia tecnológica: cada vez más actividades requieren de plataformas digitales, y estas a su vez generan grandes volúmenes de datos que circulan a través de redes de comunicación. Este fenómeno, conocido como “**economía del dato**”, ha convertido a la información en un recurso equiparable al capital o la energía.

Sin embargo, este desarrollo acarrea también una **exposición creciente a riesgos y amenazas**. La **ciberseguridad** y la **privacidad** se sitúan en el centro del debate académico, empresarial y político por varias razones:

- **Incremento de amenazas externas e internas:** ataques de ransomware, robo de identidad, filtraciones de datos, fraudes financieros, ataques de denegación de servicio (DDoS).
- **Cibercrimen organizado:** grupos con alta capacidad técnica y motivación económica operan a nivel internacional, comercializando datos robados en la “dark web” y desarrollando malware sofisticado.
- **Geopolítica del ciberespacio:** los Estados utilizan herramientas de ciberespionaje y ciberdefensa como instrumentos estratégicos, lo que añade complejidad al panorama de la seguridad.
- **Expansión del IoT (Internet of Things):** miles de millones de dispositivos conectados (cámaras, sensores, wearables) generan datos continuamente, ampliando la superficie de ataque.

En este contexto, la **seguridad y la privacidad de la información** constituyen pilares esenciales para:

1. **Proteger los activos críticos:** desde bases de datos corporativas y patentes industriales hasta credenciales individuales y comunicaciones privadas.
2. **Garantizar la continuidad operativa:** un fallo de seguridad puede paralizar hospitales, empresas de transporte o redes eléctricas, con graves consecuencias sociales y económicas.
3. **Cumplir con la legislación vigente:** en Europa, el **Reglamento General de Protección de Datos (RGPD)** impone obligaciones estrictas en el manejo de información personal.
4. **Preservar la confianza social:** la reputación de una organización depende de su capacidad de proteger y gestionar responsablemente los datos de clientes, usuarios y empleados.

1.2. La seguridad de la información

La **seguridad de la información** se define como el conjunto de medidas técnicas, organizativas, físicas y administrativas diseñadas para **proteger la información y los sistemas que la procesan** frente a amenazas intencionadas (ataques) o accidentales (fallos humanos, errores técnicos, desastres naturales).

Su núcleo conceptual descansa en la **triada CIA**:

1. Confidencialidad

Garantiza que los datos solo puedan ser accedidos por personas o sistemas autorizados. La confidencialidad se logra mediante:

- **Cifrado de la información** (AES, RSA).
- **Controles de acceso** (contraseñas robustas, autenticación multifactor, biometría).
- **Redes seguras** (VPN, firewalls, segmentación de redes).

2. Integridad

Asegura que la información se mantenga completa, exacta y no se modifique sin autorización. Ejemplos de mecanismos de integridad:

- **Funciones hash criptográficas** (SHA-256).
- **Firmas digitales**.
- **Registros de auditoría** que permiten verificar cambios.

3. Disponibilidad

Implica que los datos y servicios estén accesibles cuando los usuarios legítimos los necesiten. La disponibilidad se garantiza mediante:

- **Sistemas redundantes** (RAID, servidores espejo).
- **Planes de recuperación ante desastres (DRP).**
- **Copias de seguridad periódicas.**
- **Protección frente a ataques DDoS.**

Además de la triada CIA, hoy en día se añaden otros principios relevantes como la **trazabilidad** (poder rastrear todas las acciones realizadas sobre los datos), la **resiliencia** (capacidad de recuperación rápida tras un ataque) y la **responsabilidad proactiva** (anticiparse a riesgos, no solo reaccionar a incidentes).

La seguridad de la información se materializa a través de:

- **Normas y estándares internacionales:**
 - **ISO/IEC 27001:** sistemas de gestión de seguridad de la información.
 - **NIST Cybersecurity Framework:** marco de referencia en EE. UU. basado en identificar, proteger, detectar, responder y recuperar.
- **Modelos de madurez en ciberseguridad:** permiten a las organizaciones evaluar su nivel de protección y establecer planes de mejora.
- **Centros de Operaciones de Seguridad (SOC):** monitorizan en tiempo real las amenazas y gestionan incidentes.

La relevancia práctica de la seguridad de la información se observa en la **cifra creciente de ciberataques**. Informes como el de Check Point (2023) señalan un aumento anual del 38% en el número de ataques a empresas, lo que refleja la necesidad urgente de integrar la seguridad como parte central de la estrategia corporativa.

1.3. La privacidad de la información

La **privacidad de la información** se refiere al derecho de las personas a **decidir cómo se recopilan, procesan, almacenan y comparten sus datos personales**.

A diferencia de la seguridad, que protege los datos frente a amenazas externas, la privacidad se centra en **respetar la voluntad del titular** y los límites impuestos por la legislación.

1.3.1. Marco legal

La privacidad está regulada por diferentes normas internacionales:

- **Reglamento General de Protección de Datos (RGPD, UE, 2018):** establece principios como licitud, lealtad, transparencia, minimización de datos y responsabilidad proactiva. Introduce obligaciones para las organizaciones (notificación de brechas, nombramiento de Delegados de Protección de Datos).
- **LOPDGDD (España, 2018):** adapta el RGPD al ordenamiento jurídico nacional.
- **CCPA (California Consumer Privacy Act) y LGPD (Lei Geral de Proteção de Dados, Brasil):** reflejan una tendencia global hacia la protección de datos.

1.3.2. Derechos de los individuos

El RGPD reconoce derechos fundamentales, entre ellos:

- **Acceso:** conocer qué datos personales se poseen y cómo se utilizan.
- **Rectificación:** corregir información inexacta.
- **Supresión** (“derecho al olvido”): solicitar la eliminación de datos cuando ya no sean necesarios.
- **Portabilidad:** trasladar los datos a otro proveedor de servicios.
- **Limitación del tratamiento:** restringir temporalmente el uso de los datos.

1.3.3. Diferencias entre seguridad y privacidad

- **Seguridad:** busca evitar accesos no autorizados, proteger datos frente a amenazas y garantizar su disponibilidad.
- **Privacidad:** garantiza que los datos se recojan y usen solo con fines legítimos y autorizados.

En síntesis: **puede haber seguridad sin privacidad, pero no privacidad sin seguridad.**

1.3.4. Relevancia en la era digital

La privacidad adquiere un papel crucial en un mundo en el que cada interacción digital genera datos:

- **Redes sociales:** se comparten voluntariamente grandes cantidades de información personal.

- **Aplicaciones móviles:** recopilan datos de ubicación, hábitos de consumo y preferencias.
- **Comercio electrónico:** requiere datos financieros y patrones de compra.
- **Dispositivos IoT:** relojes inteligentes, altavoces conectados y sensores recopilan datos de salud, voz o actividad diaria.

El uso indebido de estos datos puede derivar en:

- **Vulneraciones de derechos fundamentales.**
- **Discriminación algorítmica** (ej. rechazos de créditos basados en perfiles de datos).
- **Pérdida de confianza en instituciones y empresas.**

Por todo ello, la privacidad de la información no es solo un requisito legal, sino también un imperativo **ético y social** en la sociedad digital.

2. Tratamiento de la información

El **tratamiento de la información** hace referencia a todas las operaciones y procesos que se realizan sobre los datos, ya sea de forma manual (papel, archivos físicos) o mediante sistemas automatizados (software, bases de datos, algoritmos de inteligencia artificial).

2.1. Ciclo de vida de la información

2.1.1. Recopilación

La recopilación es el **punto de entrada de los datos** en el sistema. Puede hacerse de forma explícita (cuando el usuario entrega voluntariamente información) o implícita (cuando los sistemas la obtienen automáticamente).

Ejemplos de la vida real:

- **Formularios web:** al registrarse en una red social, se solicitan nombre, correo electrónico y fecha de nacimiento.
- **Sensores IoT:** un reloj inteligente recopila ritmo cardíaco y pasos diarios.
- **Registros administrativos:** en un hospital, el paciente entrega información médica al ingresar.

👉 **Riesgo:** si en esta fase no se aplican principios de **minimización de datos**, se puede recopilar más información de la necesaria, aumentando la exposición a brechas de seguridad.

2.1.2. Almacenamiento

Una vez recopilados, los datos se **conservan** en distintos soportes: bases de datos relacionales, servidores en la nube, discos duros físicos o incluso archivos en papel.

Ejemplos:

- **Banco:** conserva el historial de transacciones de un cliente en un servidor seguro durante el tiempo legalmente requerido.
- **Universidad:** almacena los expedientes académicos en un sistema de gestión interna.
- **Google Drive / Dropbox:** servicios en la nube que guardan información personal y laboral de millones de usuarios.

👉 **Riesgo:** el almacenamiento inseguro o sin cifrado puede derivar en accesos indebidos (ejemplo: filtraciones masivas de contraseñas de LinkedIn en 2012).

2.1.3. Uso

El uso implica que los datos se **procesen con una finalidad legítima y transparente**, previamente informada al titular.

Ejemplos:

- **Netflix:** usa el historial de visionado de cada usuario para recomendar nuevas series mediante algoritmos de machine learning.
- **Sanidad pública:** analiza datos epidemiológicos para detectar brotes de enfermedades.
- **E-commerce:** un supermercado online personaliza las ofertas en función del historial de compras del cliente.

👉 Riesgo: un uso no autorizado (ejemplo: **escándalo de Cambridge Analytica en 2018**, donde se usaron datos de Facebook para manipulación política).

2.1.4. Eliminación

Cuando los datos dejan de ser necesarios, deben ser **suprimidos o anonimizados** de forma segura, respetando los plazos legales.

Ejemplos:

- **Entidad bancaria:** elimina registros de operaciones pasados X años, según normativa de prevención de blanqueo de capitales.
- **Empresa de RRHH:** borra los CV de candidatos no seleccionados después de un tiempo prudencial.
- **Universidad:** destruye exámenes en papel tras digitalizar y finalizar el proceso de reclamaciones.

👉 Riesgo: no eliminar correctamente datos sensibles puede provocar su recuperación por terceros (ejemplo: venta de discos duros usados en eBay que aún contenían historiales clínicos).

Responsabilidades en el tratamiento

- **Responsable del tratamiento:** decide la finalidad y los medios del tratamiento.
 - Ejemplo: un hospital público es responsable de los historiales médicos de sus pacientes.
- **Encargado del tratamiento:** procesa los datos en nombre del responsable.
 - Ejemplo: una empresa de cloud computing que almacena los datos de un hospital.

Obligaciones clave:

1. Documentar actividades de tratamiento.
2. Establecer medidas de seguridad apropiadas.
3. Informar de manera transparente a los titulares.

4. Notificar brechas de seguridad a la autoridad competente (en la UE, a la AEPD en 72 horas).
-

2.2. Clasificación de la información

La **clasificación de la información** consiste en asignar niveles de protección en función de la **sensibilidad, el valor y el riesgo** que supone su exposición.

Niveles comunes y ejemplos:

1. Información pública

- Datos accesibles sin restricción.
- Ejemplo: notas de prensa de una institución, horarios de transporte público.

2. Información interna

- Uso exclusivo dentro de la organización.
- Ejemplo: manuales de procedimientos de una empresa.

3. Información confidencial

- Requiere un control de acceso, ya que su filtración puede causar daños.
- Ejemplo: contratos de clientes, estrategias de marketing, expedientes médicos.

4. Información restringida

- Máxima protección; su pérdida tendría un impacto crítico.
- Ejemplo: credenciales de acceso a sistemas financieros, algoritmos propios de Google, planos de infraestructuras críticas.

Criterios de clasificación:

- **Valor:** importancia estratégica o económica.
- **Impacto:** consecuencias de divulgación, pérdida o alteración.
- **Requisitos legales:** leyes que obligan a niveles específicos (ej. protección reforzada de datos biométricos o de salud en el RGPD).

👉 Caso real: en 2014, el robo de información confidencial de **Sony Pictures** expuso correos internos y estrategias de negocio, causando graves pérdidas económicas y de reputación.

2.3. Protección de la información

Para mitigar los riesgos, la información debe protegerse mediante un enfoque de **defensa en profundidad**, es decir, aplicar múltiples barreras de seguridad que dificulten la labor de un atacante.

Tipos de controles:

1. Controles físicos

- Restringen el acceso a instalaciones y equipos.
- Ejemplos: cerraduras electrónicas, cámaras de vigilancia, guardias de seguridad, tarjetas de identificación.
- Caso real: en centros de datos de Amazon Web Services (AWS), el acceso físico está limitado con biometría y vigilancia 24/7.

2. Controles técnicos

- Basados en herramientas tecnológicas.
- Ejemplos: cifrado, firewalls, antivirus, autenticación multifactor (MFA), sistemas de detección de intrusiones (IDS/IPS).
- Caso real: tras el ataque de ransomware WannaCry (2017), muchos hospitales tuvieron que reforzar la seguridad técnica de sus redes.

3. Controles administrativos

- Basados en políticas, normas y formación.
- Ejemplos: políticas de contraseñas, formación en phishing, planes de respuesta a incidentes.
- Caso real: en 2020, un empleado de Twitter fue engañado (ingeniería social), lo que permitió a atacantes tomar el control de cuentas verificadas.

Conclusión

La **seguridad y privacidad de la información** no son estáticas, sino disciplinas dinámicas que deben adaptarse a amenazas emergentes como:

- **Ciberataques basados en IA generativa** (ejemplo: deepfakes usados para fraude).
- **Riesgos del IoT masivo** (ejemplo: cámaras domésticas hackeadas para espionaje).
- **Avances en criptografía cuántica**, que obligarán a implantar cifrado post-cuántico.

Su gestión efectiva requiere integrar tres dimensiones:

1. **Tecnología:** herramientas de cifrado, monitorización, redundancia.
2. **Marco legal:** cumplimiento del RGPD, CCPA y normas internacionales.
3. **Cultura organizacional:** concienciación de empleados y compromiso ético.

En el siglo XXI, **proteger la información no es solo un requisito técnico, sino un imperativo ético y social**, ya que está directamente ligado a los **derechos fundamentales de las personas** y a la **confianza en el ecosistema digital**.

Referencias clave

- ISO/IEC 27001:2022. *Sistemas de Gestión de Seguridad de la Información*.
- NIST Cybersecurity Framework 2.0 (2023).
- Reglamento General de Protección de Datos (UE 2016/679).
- LOPDGDD (España, 2018).
- IBM (2023). *Cost of a Data Breach Report*.

3. Almacenamiento de la información

El almacenamiento de la información constituye una de las funciones críticas en la gestión de datos. No se trata únicamente de guardar archivos en un soporte físico o en la nube, sino de garantizar que los datos permanezcan íntegros, disponibles y protegidos frente a pérdidas accidentales, accesos no autorizados o desastres imprevistos.

Importancia:

- Mantener la información íntegra y accesible.
- Cumplir con los plazos legales de conservación.
- Facilitar la recuperación ante incidentes o desastres.

Aspectos clave:

- Ubicación segura: Centros de datos con medidas de protección física y digital.
- Control de acceso: Limitación de usuarios y registro de actividades.
- Integridad de datos: Mecanismos que eviten la corrupción o manipulación no autorizada.
- Respaldo y recuperación: Copias de seguridad periódicas y planes de contingencia para garantizar continuidad de servicio.

Importancia del almacenamiento seguro

La relevancia del almacenamiento de la información se entiende mejor si se analizan sus principales objetivos:

- Preservar la integridad de los datos: garantizar que la información no sea alterada sin autorización.
- Asegurar la disponibilidad: los datos deben poder consultarse cuando se requieran, evitando caídas o bloqueos.
- Cumplimiento normativo: muchas legislaciones obligan a conservar información durante períodos determinados. Ejemplo: la normativa fiscal en España exige conservar documentación contable al menos durante 6 años.
- Resiliencia ante incidentes: disponer de mecanismos que permitan recuperar la información tras fallos técnicos, ataques informáticos o catástrofes naturales.

Objetivo	Explicación	Ejemplo
Integridad	Garantizar que los datos no sean	Verificación de hash en copias de bases de datos.

	alterados o corrompidos.	
Disponibilidad	Asegurar el acceso a la información cuando se necesite.	Servidores en alta disponibilidad en hospitales.
Cumplimiento legal	Mantener datos por el tiempo requerido por ley.	Empresas españolas deben conservar registros contables 6 años.
Resiliencia	Poder recuperar datos tras un desastre.	Centros de datos con almacenamiento en diferentes ubicaciones.

Este aspecto no afecta solo a empresas u organismos públicos. A nivel personal, los usuarios almacenan cantidades crecientes de información sensible: fotografías familiares, historiales médicos, credenciales de acceso, información bancaria. Una pérdida puede tener consecuencias tanto emocionales como económicas.

3.1. Copias de seguridad

Las copias de seguridad (backups) son la herramienta más efectiva para garantizar la continuidad del negocio y la recuperación de la información tras un incidente. Representan la última línea de defensa frente a ataques como el ransomware o a fallos de hardware.

Tipos de copias de seguridad

Copia completa

- Se realiza una réplica íntegra de todos los datos seleccionados.
- Ventajas: recuperación rápida y sencilla.
- Desventajas: requiere más tiempo y espacio de almacenamiento.
- Ejemplo: copia semanal de toda la base de datos de una empresa.

Copia incremental

- Solo almacena los cambios efectuados desde la última copia (completa o incremental).

- Ventajas: ahorro de espacio y tiempo.
- Desventajas: la restauración puede ser más compleja, pues depende de múltiples copias encadenadas.

Copia diferencial

- Guarda todos los cambios desde la última copia completa.
- Ventajas: equilibrio entre rapidez y espacio.
- Desventajas: requiere más almacenamiento que la incremental.

Tipo	Descripción	Ventajas	Desventajas
Completo	Copia íntegra de todos los datos seleccionados.	Restauración rápida, sencilla.	Requiere más espacio y tiempo.
Incremental	Copia solo de los cambios desde la última copia.	Ocupa poco espacio, rápida ejecución.	Restauración más lenta (varias copias encadenadas).
Diferencial	Copia de los cambios desde la última copia completa.	Equilibrio entre rapidez y espacio.	Ocupa más que la incremental.

Estrategia 3-2-1

La estrategia 3-2-1 es el estándar internacionalmente recomendado:

- 3 copias de los datos importantes.
- 2 soportes diferentes (ej.: disco local y almacenamiento en la nube).
- 1 copia en una ubicación externa (off-site), idealmente en otra ciudad o país.

Ejemplo real: una empresa mantiene una copia en servidores internos, otra en la nube de Microsoft Azure y una tercera en cintas almacenadas en un centro de respaldo externo.

Pruebas periódicas

Un error habitual es dar por hecho que las copias funcionan sin verificarlo. Muchas organizaciones descubren que sus copias estaban corruptas o incompletas justo en el momento crítico.

Por ello, se recomienda realizar pruebas de restauración periódicas para validar su integridad y tiempo de recuperación (Recovery Time Objective, RTO).

3.2. Borrado seguro de la información

Borrar un archivo en un sistema convencional no significa eliminarlo definitivamente. En la mayoría de casos, lo que desaparece es la referencia en el sistema de archivos, pero los datos siguen almacenados en el disco hasta que son sobrescritos.

3.2.1. Métodos de borrado seguro

Sobrescritura

- Se reescriben varias veces los sectores donde residían los datos con patrones aleatorios o específicos.
- Cuantas más pasadas se realizan, más difícil resulta la recuperación con técnicas forenses.

Degradación magnética (degaussing)

- Aplicación de un campo magnético intenso que inutiliza los soportes magnéticos (discos duros tradicionales, cintas).
- Método rápido, pero destruye el soporte para futuros usos.

Destrucción física

- Trituración, pulverización o incineración de los soportes.
- Método definitivo cuando la confidencialidad es prioritaria (ej.: documentos clasificados en el ámbito militar).

Método	Explicación	Uso habitual
Sobrescritura	Reescribir varias veces con datos aleatorios.	Eliminación de archivos en discos duros antes de su reutilización.

Degradación magnética (degaussing)	Campo magnético borra irreversiblemente.	Centros de datos que desechan discos magnéticos.
Destrucción física	Trituración, pulverización o incineración.	Documentación clasificada, entornos militares o gubernamentales.

3.2.2.Importancia del borrado seguro

- Prevención de fugas de información: muchos incidentes ocurren cuando dispositivos antiguos son vendidos o reciclados sin un borrado adecuado.
- Cumplimiento normativo: el Reglamento General de Protección de Datos (RGPD, UE 2016/679) exige garantizar la supresión efectiva de datos personales cuando ya no son necesarios.
- Optimización de recursos: permite liberar espacio en sistemas de almacenamiento sin comprometer la seguridad.

4. Principales amenazas a la información

El panorama actual de la ciberseguridad está marcado por el aumento en volumen, complejidad y consecuencias de los ciberataques.

4.1. Panorama actual

- Mayor volumen: Cada minuto se registran millones de intentos de intrusión en sistemas conectados a Internet.
- Más sofisticación: Los atacantes usan inteligencia artificial, técnicas de ingeniería social avanzada y malware polimórfico (que cambia de forma para evitar detección).
- Impacto económico: El informe de Cybersecurity Ventures (2023) estima que el coste global del cibercrimen superará los 10,5 billones de dólares anuales en 2025.
- Impacto reputacional: una sola brecha puede destruir la confianza de clientes y socios en cuestión de horas.

4.2. Objetivos de los atacantes

- Robo de información: datos financieros, credenciales de acceso, secretos industriales.
- Extorsión económica: ataques de ransomware que bloquean sistemas hasta que se pague un rescate.
- Interrupción de servicios: ataques de denegación de servicio distribuido (DDoS).
- Suplantación de identidad: robo de identidades digitales para cometer fraudes.

Ejemplo real: En 2021, el ataque de ransomware a Colonial Pipeline en EE. UU. provocó la paralización de uno de los principales oleoductos del país y obligó al pago de un rescate de 4,4 millones de dólares.

4.3. Phishing

El phishing es una de las amenazas más comunes y efectivas. Consiste en la suplantación de identidad para engañar al usuario y obtener información confidencial.

Tipos de phishing

- Email phishing: correos que simulan ser de bancos o empresas.
- Smishing: a través de SMS.
- Vishing: mediante llamadas telefónicas.
- Spear phishing: ataque dirigido a una persona o institución específica, con mensajes muy personalizados.

Señales de alerta

- Mensajes con urgencia o amenazas.
- Errores gramaticales o traducciones pobres.
- Remitentes sospechosos que no coinciden con direcciones oficiales.
- Enlaces acortados o con direcciones poco claras.

Prevención

- Verificar siempre la procedencia de mensajes.

- No hacer clic en enlaces sospechosos.
- Utilizar autenticación multifactor para minimizar riesgos incluso si se roban credenciales.

Ejemplo real: En 2020, el spear phishing fue usado contra empleados de Twitter, logrando acceso a cuentas verificadas como las de Barack Obama o Elon Musk para difundir fraudes con criptomonedas.

Tipo	Características	Ejemplo real
Email phishing	Correos que simulan bancos o servicios.	Emails falsos de PayPal solicitando verificación.
Smishing	Mensajes SMS fraudulentos.	Falsos SMS de empresas de mensajería.
Vishing	Llamadas telefónicas suplantando soporte técnico.	Estafas de “Microsoft” ofreciendo ayuda remota.
Spear phishing	Ataques personalizados con información previa.	Robo de credenciales en la campaña contra Twitter (2020).

4.4. Malware

El término malware (malicious software) abarca cualquier programa diseñado para infiltrarse o dañar un sistema.

Tipos principales

- Virus: se adjuntan a archivos y se ejecutan al abrirlos.
- Ransomware: bloquea datos y exige un rescate.
- Spyware: recopila información sin consentimiento (contraseñas, hábitos).
- Troyanos: se hacen pasar por software legítimo y crean accesos ocultos.
- Gusanos: se propagan automáticamente a través de redes.

Vías de infección

- Descargas desde sitios no seguros.
- Archivos adjuntos en correos fraudulentos.
- Páginas web comprometidas o anuncios maliciosos.

Medidas de protección

- Antivirus actualizados.
- Aplicar políticas de navegación segura.
- Concienciar a los usuarios sobre los riesgos de abrir archivos o enlaces sospechosos.

Ejemplo real: En 2017, el ransomware WannaCry afectó a más de 200.000 equipos en 150 países, paralizando servicios críticos como el sistema sanitario británico (NHS).

Tipo	Descripción	Ejemplo real
Virus	Se adjuntan a archivos ejecutables.	CIH ("Chernobyl"), borró BIOS de PCs (1999).
Ransomware	Bloquea sistemas y pide rescate.	WannaCry (2017), afectó al NHS británico.
Spyware	Roba información en secreto.	Pegasus, usado contra periodistas y activistas.
Troyano	Se hace pasar por software legítimo.	Zeus, robaba credenciales bancarias.
Gusano	Se propaga automáticamente en redes.	Conficker, infectó millones de equipos en 2008.

5. Contraseñas y autenticación

5.1. La importancia de las contraseñas

Las contraseñas son la herramienta de autenticación más extendida en el mundo digital. Desde el acceso a redes sociales hasta sistemas bancarios, casi todas las plataformas utilizan contraseñas como primer filtro de identificación.

No obstante, constituyen también uno de los puntos más débiles de la seguridad digital. Estudios como el Verizon Data Breach Investigations Report (2023) indican que más del 80% de las brechas de seguridad están relacionadas con el uso indebido de credenciales.

Los errores más comunes entre los usuarios incluyen:

- Utilizar contraseñas débiles (ej.: "123456", "password", "qwerty").
- Reutilizar la misma contraseña en múltiples servicios.
- Guardarlas en lugares inseguros (post-it, archivos sin cifrar, chats personales).
- No actualizarlas tras sospechas de filtración.

El problema de fondo es que los atacantes cuentan hoy con herramientas automáticas capaces de probar millones de combinaciones por segundo (ataques de fuerza bruta) o de utilizar diccionarios con las contraseñas más comunes (ataques de diccionario).

5.2. Buenas prácticas en la gestión de contraseñas

Características de una contraseña segura

1. Longitud: Cuanto más larga, más segura. La recomendación mínima es de 12 caracteres, pero lo ideal es 16 o más en entornos sensibles.
2. Complejidad: Debe incluir letras mayúsculas, minúsculas, números y caracteres especiales.
3. Originalidad: Nunca utilizar datos personales como nombre, fecha de nacimiento, matrícula del coche o número de teléfono.
4. Imprevisibilidad: Evitar patrones fáciles (ej.: "abcd1234", "qwerty!").

Ejemplo de contraseña insegura: lorena2025

Ejemplo de contraseña segura: Jk8!sP3qL\$7x

Recomendaciones operativas

- Contraseñas únicas para cada servicio: Si una se filtra, no debe comprometer otras cuentas.
- Cambios periódicos: No se trata de cambiarlas cada mes sin motivo, sino de actualizarlas tras incidentes o en plazos razonables (6-12 meses) para entornos críticos.
- Gestores de contraseñas: Herramientas como Bitwarden, KeePass, LastPass o 1Password generan contraseñas seguras y las almacenan cifradas. Así, el usuario solo necesita recordar una clave maestra.
- Doble protección: Combinar la contraseña con autenticación multifactor (MFA) siempre que sea posible.
- No compartirlas nunca: Una contraseña compartida deja de ser privada y compromete la trazabilidad.

Ejemplo real: En 2019, se filtraron más de 773 millones de credenciales en la base de datos *Collection #1*, debido a reutilización masiva de contraseñas en múltiples servicios.

Práctica	Justificación
Longitud mínima de 12 caracteres	Aumenta la complejidad contra ataques de fuerza bruta.
Mezcla de caracteres	Dificulta ataques de diccionario.
Evitar datos personales	Nombres, fechas, DNI son fáciles de adivinar.
Contraseñas únicas	Evita el “efecto dominó” si una se filtra.
Gestores de contraseñas	Facilitan recordar claves seguras.

5.3. Autenticación multifactor (MFA)

La autenticación multifactor surge como respuesta a las limitaciones de las contraseñas. Su objetivo es verificar la identidad del usuario mediante dos o más factores diferentes, lo que dificulta en gran medida el acceso no autorizado.

Factores de autenticación

1. Algo que sabes: Contraseña, PIN, respuesta a preguntas de seguridad.
2. Algo que tienes: Tarjeta inteligente, token físico, dispositivo móvil (código SMS, app autenticadora).
3. Algo que eres: Características biométricas (huella dactilar, reconocimiento facial, iris, voz).

Beneficios

- Incremento de la seguridad: Aunque un atacante robe la contraseña, necesitará el segundo factor.
- Protección contra phishing: Los correos fraudulentos que buscan robar claves pierden eficacia si se exige un código adicional generado en un dispositivo físico.
- Mitigación de robo de credenciales: Incluso bases de datos filtradas con millones de contraseñas resultan insuficientes sin el segundo factor.

Ejemplos de uso

- Banca online: Envío de códigos SMS o uso de apps específicas (ej.: Google Authenticator, Authy).
- Plataformas de correo y redes sociales: Opción de activar MFA con notificaciones push o llaves físicas (ej.: YubiKey).
- Empresas: Políticas de obligatoriedad en accesos remotos a redes corporativas.

Caso real: Microsoft declaró en 2022 que el uso de MFA bloquea más del 99% de los intentos de acceso no autorizados a cuentas de sus usuarios.

Factor	Ejemplo	Nivel de seguridad
Algo que sabes	Contraseña, PIN	Bajo
Algo que tienes	Token, app móvil	Medio
Algo que eres	Huella, rostro	Alto

6. Protección del puesto de trabajo

El puesto de trabajo, ya sea en oficina o remoto, constituye un punto crítico de exposición a amenazas. No sirve de nada disponer de servidores y redes altamente protegidas si el eslabón final (el ordenador o dispositivo del usuario) queda vulnerable.

La protección debe abordarse desde tres perspectivas complementarias:

- Física: Proteger los dispositivos y el entorno.
- Lógica: Blindar el software, redes y accesos digitales.
- Humana: Concienciar a los usuarios, que suelen ser el objetivo principal de los atacantes.

6.1. Medidas de protección física

La seguridad física protege los equipos y dispositivos frente a robos, daños accidentales o catástrofes ambientales.

Ejemplos de medidas físicas

- Dispositivos:
 - Bloqueo automático tras minutos de inactividad.
 - Uso de candados o cables de seguridad en portátiles.
 - Sistemas de borrado remoto en caso de pérdida de móviles.
- Control de acceso a instalaciones:
 - Tarjetas electrónicas o identificación biométrica.
 - Registro de visitantes en áreas críticas.
 - Cámaras de videovigilancia y alarmas.
- Protección ambiental:
 - Control de temperatura y humedad en salas de servidores.
 - Sistemas antiincendios (detectores, rociadores, extintores especializados).
 - Medidas contra inundaciones y cortes eléctricos (UPS y generadores).

Ejemplo real: En 2021, un incendio en un centro de datos de OVHcloud en Estrasburgo dejó inoperativos miles de servicios. Aunque había copias de seguridad, la catástrofe mostró la importancia de contar con planes de contingencia físicos y redundancia geográfica.

6.2. Medidas de protección lógica

La seguridad lógica abarca todas las medidas digitales implementadas en software, redes y sistemas.

Áreas principales

1. Mantenimiento de sistemas:
 - Actualizaciones regulares de software.
 - Instalación de parches de seguridad en cuanto se publican.
 - Eliminación de programas obsoletos.
2. Protección perimetral:
 - Firewalls correctamente configurados.
 - Sistemas de detección y prevención de intrusiones (IDS/IPS).
 - Monitorización de tráfico sospechoso.
3. Cifrado de información:
 - Datos en reposo: discos duros y memorias cifradas.
 - Datos en tránsito: protocolos HTTPS, TLS, VPN.
 - Uso obligatorio de cifrado en dispositivos corporativos.
4. Conexiones seguras:
 - Redes WiFi protegidas con WPA3.
 - VPN para accesos remotos a sistemas corporativos.
 - Prohibición de redes públicas no seguras.
5. Concienciación y formación:
 - Simulaciones de phishing para entrenar a los empleados.
 - Cursos periódicos de ciberseguridad.
 - Recordatorios prácticos sobre contraseñas, descargas y uso de dispositivos.

Ejemplo real: En 2020, un ataque de ransomware paralizó varios hospitales en Alemania porque un sistema crítico no había sido

actualizado con los parches de seguridad adecuados. La falta de mantenimiento fue la causa principal.

Conclusiones

La seguridad y privacidad de la información no son solo cuestiones tecnológicas, sino responsabilidades organizativas y culturales.

Puntos clave

- Responsabilidad compartida: La seguridad compete a todos: directivos, técnicos y usuarios finales.
- Protección por capas: Ninguna medida es infalible por sí sola. La combinación de controles físicos, lógicos y humanos es la estrategia más efectiva.
- Actualización constante: Las amenazas evolucionan; lo que es seguro hoy puede ser vulnerable mañana.
- Cultura de seguridad: Más importante que el mejor firewall es un usuario bien formado que sepa detectar un correo fraudulento.
- Prevención frente a reacción: Invertir en seguridad reduce costes y daños. Recuperarse de una brecha suele ser mucho más caro que prevenirla.
- Seguridad como inversión estratégica: Lejos de ser un gasto, la ciberseguridad protege el activo más valioso: la confianza.

Reflexión final: En el mundo digital actual, la seguridad no es opcional. Cada individuo, cada organización y cada institución debe asumir que proteger la información es proteger la propia continuidad y reputación.